COMSATS University Islamabad
CYC386 – Secure Software Design and Development
Midterm Lab Exam – 1-Week DevSecOps Security Sprint (Fall 2026)

# Threat Model

DFD · STRIDE · Attack Trees · CVSS v3.1

| Field | Detail |
|---|---|
| Project | MedVault – Secure Diagnostic Lab Report Portal |
| Team | MedVault |
| Member(s) | Zojaja Naveed (Fa23-bct-047)<br>Tayyeba Usman (Fa23-bct-053) |
| Instructor | Engr. Muhammad Ahmad Nawaz |
| Repository | https://github.com/Zojaja-Naveed/MedicalVault.git |
| Date | 30 October 2026 |

## 1. Scope and Assumptions

- In scope: the Flask web app, native C parser, SQLite database, file store, and the data flows between them.
- The server runs in a container; the operating system is assumed patched.
- Exploitation was performed only in the team's own lab environment.
- Jira epic: **MV-2 (Threat Modeling & Risk)**. Method: DFD + STRIDE + Attack Trees + CVSS v3.1.

## 2. Context Diagram (Level 0)

The context diagram shows MedVault as a single process and the external entities that exchange data with it.

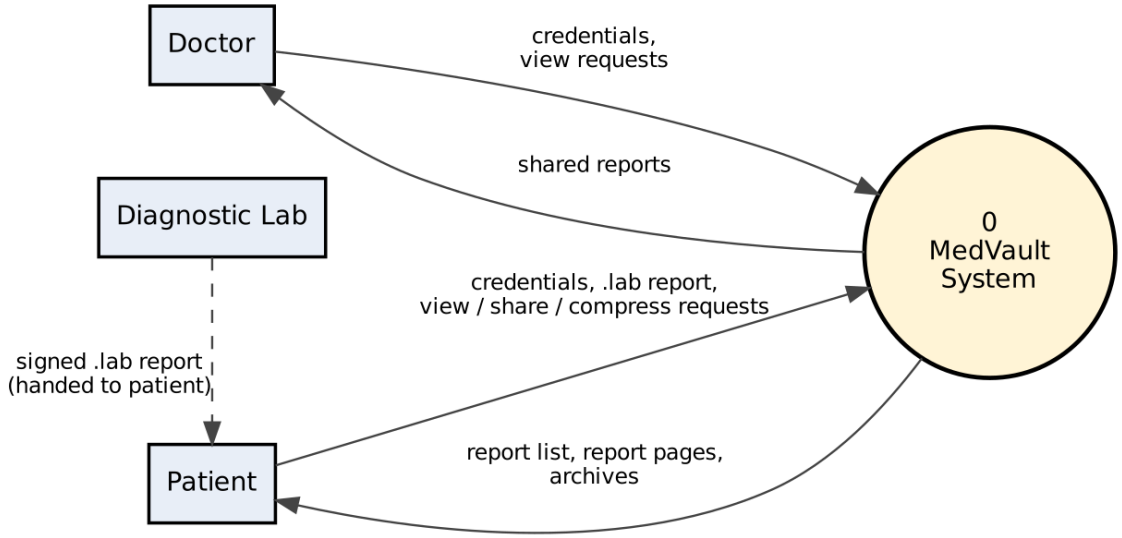



Figure 1 - Context Diagram (Level 0): box = external entity, circle = process

## 3. Level-1 Data Flow Diagram

The Level-1 DFD breaks MedVault into five processes, the native parser, and three data stores. The red dashed trust boundary separates untrusted browser input from the server; every flow that crosses it must be validated and authorized.

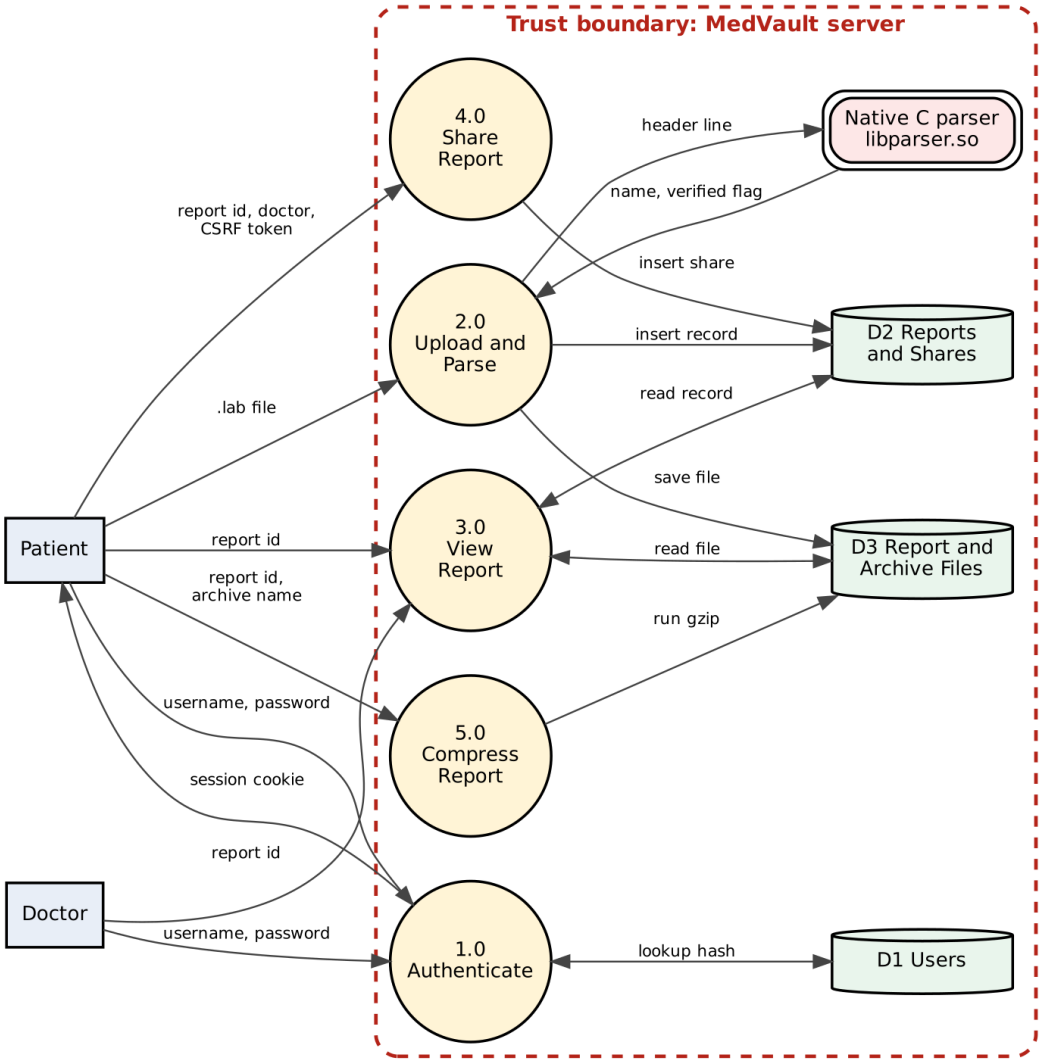



Figure 2 - Level-1 DFD. Every arrow crossing the red boundary carries untrusted input.

## 4. STRIDE Analysis

STRIDE was applied to every DFD element. Threats in **bold** are the five mandatory vulnerability classes.

| Element | S – Spoofing | T – Tampering | R – Repudiation | I – Info Disclosure | D – Denial of Service | E – Elevation of Privilege |
|---|---|---|---|---|---|---|
| Patient / Doctor (external) | Stolen or forged session cookie (T-06) | – | User denies sharing a report (T-08) | – | – | – |
| P1 Authenticate | Password guessing; session forgery via hard-coded key (T-06) | – | No login audit (T-08) | Debug pages leak internals (T-07) | Login brute-force load | Debug console gives code execution (T-07) |
| P2 Upload and Parse | – | Forged verified stamp via overflow (**T-01**) | Uploads not logged (T-08) | – | Oversize header crashes parser (**T-01**) | Memory corruption → control-flow hijack (**T-01**) |
| Native C parser | – | Adjacent memory overwritten (**T-01**) | – | – | Segfault / abort (**T-01**) | Code execution if mitigations absent (**T-01**) |
| P3 View Report | – | – | – | Read others' reports by changing ID (**T-03**) | – | Horizontal privilege escalation (**T-03**) |
| P4 Share Report | Forged cross-site share (**T-04**); UI redress click (**T-05**) | Share list changed without consent (**T-04**) | Shares not logged (T-08) | Report shared to attacker (**T-04**, **T-05**) | – | – |
| P5 Compress Report | – | Files modified via injected commands (**T-02**) | – | Arbitrary file read (**T-02**) | Injected commands kill/flood server (**T-02**) | Remote code execution (**T-02**) |
| D1 Users | – | – | – | Password hash disclosure via T-02 | – | – |
| D2 Reports and Shares | – | Direct edits via T-02 | – | Metadata disclosure via T-03 | – | – |
| D3 File store | – | Report files altered via T-02 | – | Files read via T-02 / T-03 | Disk filled with archives | – |
| Data flows (browser ↔ server) | – | Request forged cross-site (**T-04**) | – | Cookie theft over plain HTTP (residual) | – | – |

## 4.1 Threat List

| ID | Threat | STRIDE | Protection Need |
|---|---|---|---|
| T-01 | Buffer overflow in native report-header parser | T, D, E | PN-02, PN-06 |
| T-02 | OS command injection in Compress Report | T, I, D, E | PN-03 |
| T-03 | IDOR on /report/<id> | I, E | PN-01 |
| T-04 | CSRF on Share Report | S, T, I | PN-04 |
| T-05 | Clickjacking of dashboard / share UI | S, I | PN-05 |
| T-06 | Hard-coded Flask secret key → session forgery | S | PN-07 |
| T-07 | Flask debug mode enabled | I, E | PN-07 |
| T-08 | Missing audit logging | R | PN-08 |

# 5. Attack Trees

## 5.1 Attack Tree 1 – Remote command execution

Root is an OR node: any one branch reaches the goal. Each branch is an AND node: all its leaves must succeed. The easiest path before fixes is **1.1 → 1.3 → 1.4**, which needs only a free account and one form field, so T-02 is the top priority.

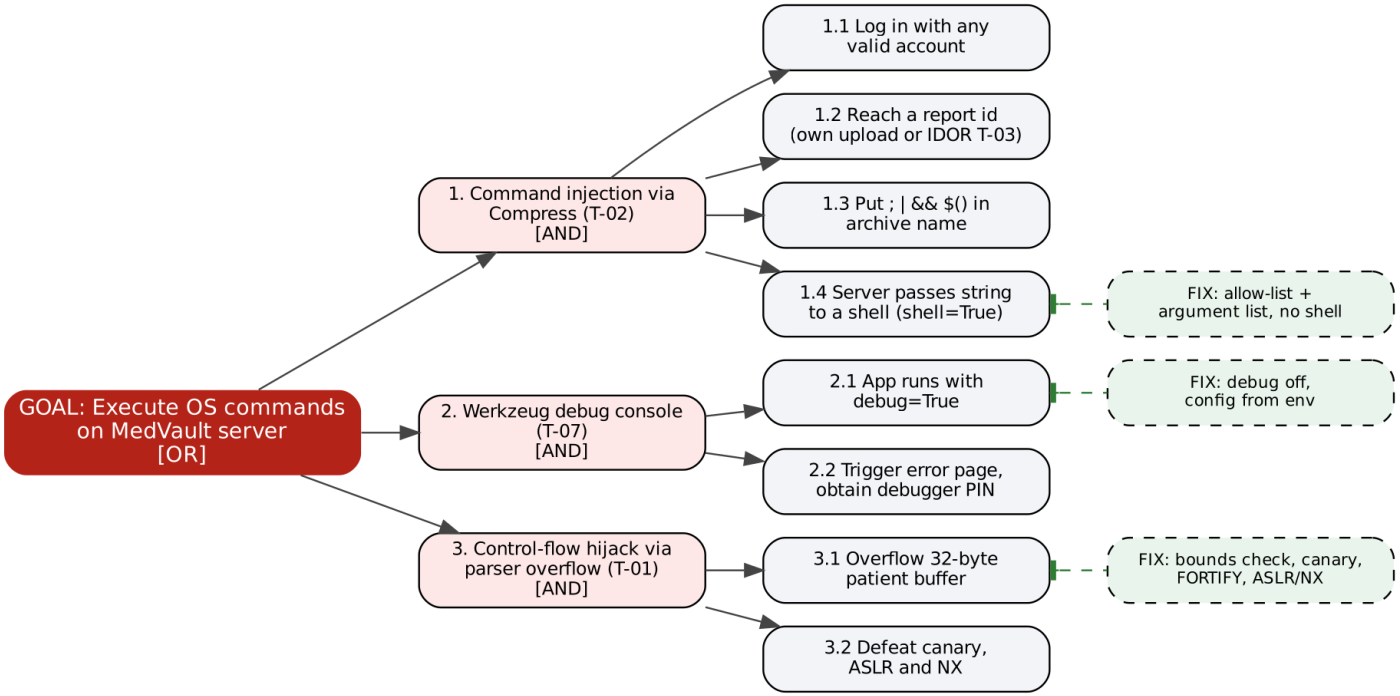



Figure 3 - Attack Tree 1: Remote command execution. Easiest path: 1.1 -> 1.3 -> 1.4

## 5.2 Attack Tree 2 – Forged "verified" medical report

Branch 1 is the buffer overflow demonstrated in the lab. Branch 3 remains a residual risk because the lab signature is a static marker rather than a cryptographic signature.

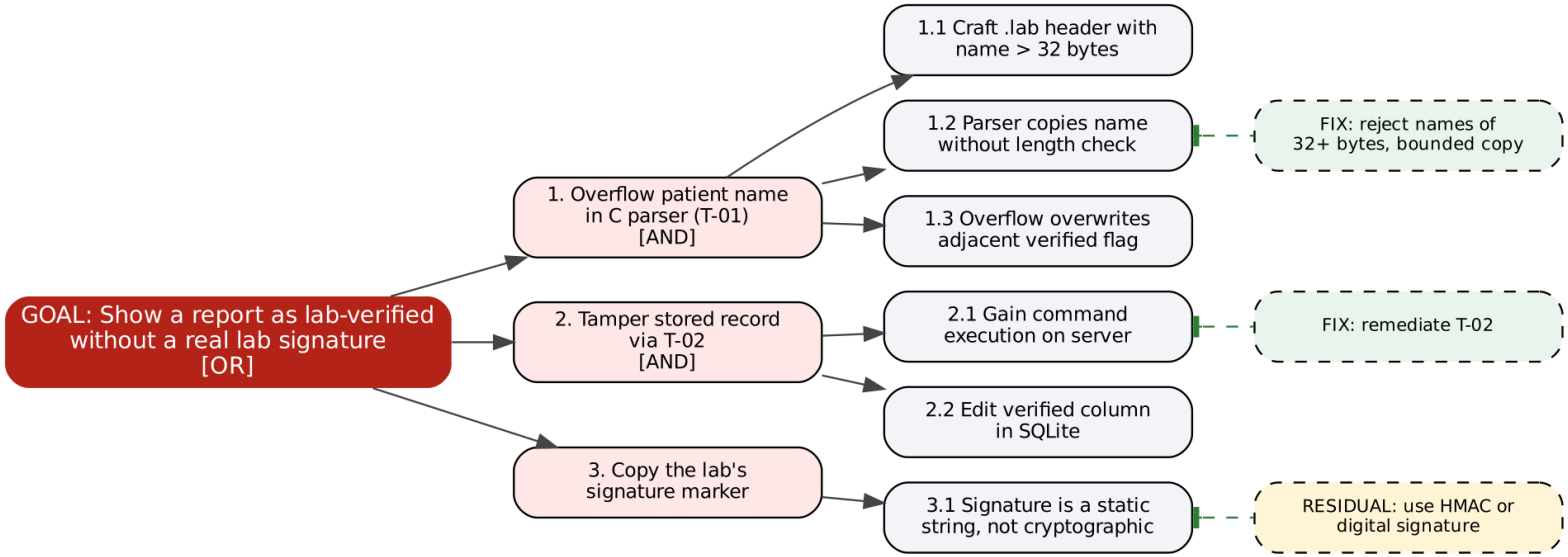



Figure 4 - Attack Tree 2: Forged verified medical report

## 6. CVSS v3.1 Scoring

| ID | Threat | Vector | Base | Severity | Justification |
|---|---|---|---|---|---|
| T-02 | Command injection | AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H | 8.8 | High | Reachable over the network with any account; no user interaction; full read/write/kill on the server |
| T-01 | Buffer overflow | AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H | 8.1 | High | Crafted upload forges the verified flag (integrity) or crashes the parser (availability); no data read |
| T-07 | Debug mode | AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H | 8.1 | High | Debugger console gives code execution, but obtaining the PIN raises attack complexity |
| T-06 | Hard-coded secret key | AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N | 7.4 | High | Anyone who reads the source can forge any user's session; the key must be found first |
| T-04 | CSRF on share | AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N | 7.1 | High | Victim only has to visit a page; report disclosed to attacker and share list altered |
| T-03 | IDOR | AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N | 6.5 | Medium | Any logged-in user reads any report by changing the ID |
| T-05 | Clickjacking | AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N | 4.3 | Medium | Requires the victim to click on a crafted page; limited integrity impact |
| T-08 | No audit log | – | – | Low | Not directly exploitable; weakens incident response |

**Environmental adjustment:** medical data requires high confidentiality (`CR:H`). With CR:H, T-03 (IDOR) rises from **6.5 to 8.3 (High)**, so it is treated as High priority.

## 7. Prioritized Risk Register

PR numbers are filled in as each fix is merged.

| Priority | ID | Threat | CVSS | Jira | Fix PR | Status | Residual Risk |
|---|---|---|---|---|---|---|---|
| 1 | T-02 | Command injection | 8.8 | MV-15 | #__ | Open | Low |
| 2 | T-03 | IDOR (environmental 8.3) | 6.5 / 8.3 | MV-16 | #__ | Open | Low |
| 3 | T-01 | Buffer overflow | 8.1 | MV-14 | #__ | Open | Low |
| 4 | T-07 | Debug mode | 8.1 | MV-13 | #__ | Open | Low |
| 5 | T-06 | Hard-coded secret key | 7.4 | MV-13 | #__ | Open | Low |
| 6 | T-04 | CSRF | 7.1 | MV-17 | #__ | Open | Low |
| 7 | T-05 | Clickjacking | 4.3 | MV-18 | #__ | Open | Very low |

| Priority | ID | Threat | CVSS | Jira | Fix PR | Status | Residual Risk |
|---|---|---|---|---|---|---|---|
| 8 | T-08 | No audit log | – | MV-13 | #__ | Open | Medium |

## 8. Residual Risk Statement

After all fixes, the following risks remain and are accepted for this sprint:

| Risk | CIA | Reason accepted / future work |
|---|---|---|
| Lab signature is a static marker, not cryptographic | I | Replace with an HMAC or digital signature from the lab |
| No HTTPS in the local lab setup | C | Use TLS (reverse proxy + certificate) on the EC2 deployment |
| No login rate limiting or MFA | C, I | Add rate limiting (e.g. Flask-Limiter) and MFA |
| SQLite data not encrypted at rest | C | Use disk or database encryption in production |
| C parser is memory-unsafe by language | I, A | Isolated behind strict length checks and compiler hardening; could be rewritten in Rust |